

Разработка защищенной БД информационной системы «Хлебозавод»

Slop-Bakery • PostgreSQL • FastAPI • Docker Compose

Е. Д. Девяткин, ИУ8-84 • Москва, 2026

Цель, задачи и структура

Цель

Разработать систему хлебозавода с контролем доступа, целостности данных и защищённой обработкой бизнес-операций.

Задачи

- построить модели предметной области
- описать физическую модель PostgreSQL
- реализовать веб-интерфейс и серверную логику
- настроить роли, права и ограничения
- показать примеры реализации защиты
- структура: анализ → модели → реализация → защита → отчёты

Предметная область



Поставки

- поставщик
- сырьё
- приёмка

Производство

- техкарта
- партия
- качество

Реализация

- заказ
- оплата
- отгрузка

Роли и интерфейс

admin

пользователи
• аудит •
статусы

client

свои заказы •
счета •
отгрузки

technologist

техкарты •
производство

warehouse

поставки •
склад •
отгрузки

quality

проверки
качества

Угрозы и средства защиты

Доступ

- НСД
- прямые URL
- подмена POST
→ роли, 403, action-level permissions

Данные

- SQL-инъекции
- подбор паролей
- некорректный ввод
→ параметры, bcrypt, validation

Целостность

- неверные статусы
- отрицательные суммы
- дубли документов
→ PK/FK/CHECK, индексы, backup

Инфологическая модель

Клиентский контур

customers → customer_orders →
order_items → invoices → shipments

Поставочный

suppliers → supplier_materials →
deliveries → raw_material_stock

Производственный контур

products → tech_cards → recipe_items
→ production_batches →
finished_goods_stock

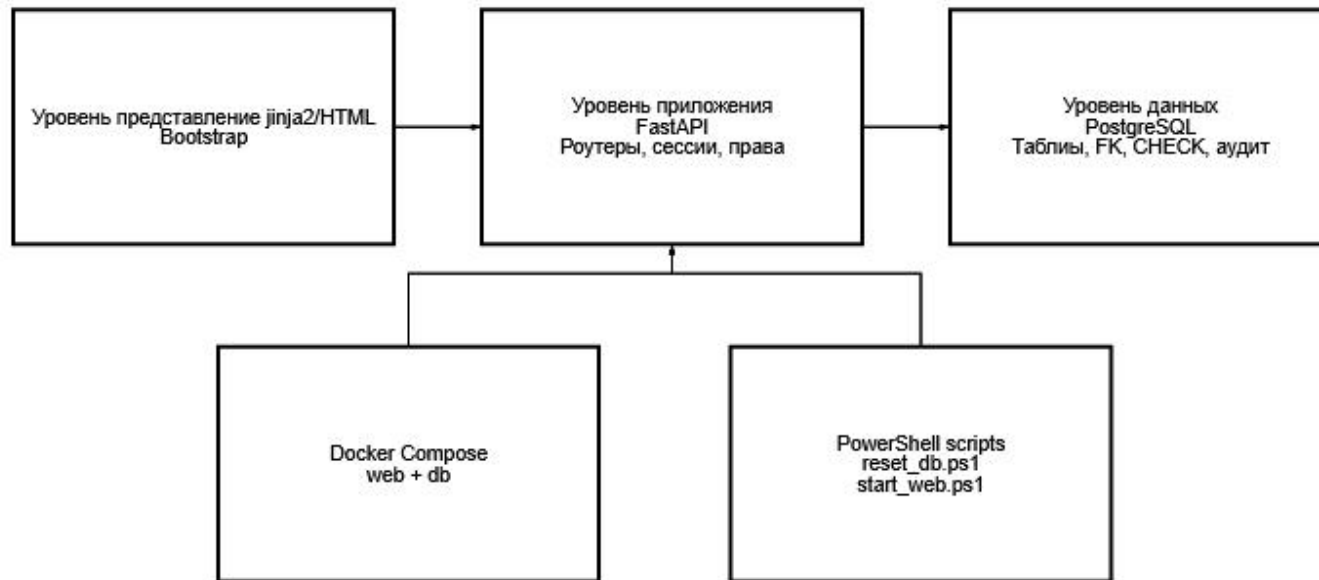
Контур качества и безопасности

quality_checks контролируют допуск партий;
users, roles и audit_log фиксируют доступ и
действия

Главная идея модели

Каждая операция привязана к документу и партии: заказ связан со счётом и отгрузкой, поставка — с поставщиком и сырьём, производство — с техкартой и контролем качества.

Логическая структура



Роли уровней

- Jinja2: интерфейс
- FastAPI: бизнес-логика
- PostgreSQL: данные
- Docker: воспроизводимость

Физическая модель PostgreSQL

Ключи

PK/FK для связей документов и партий

Индексы

уникальность номеров и запрет дублей

CHECK

количества, даты, paid_at

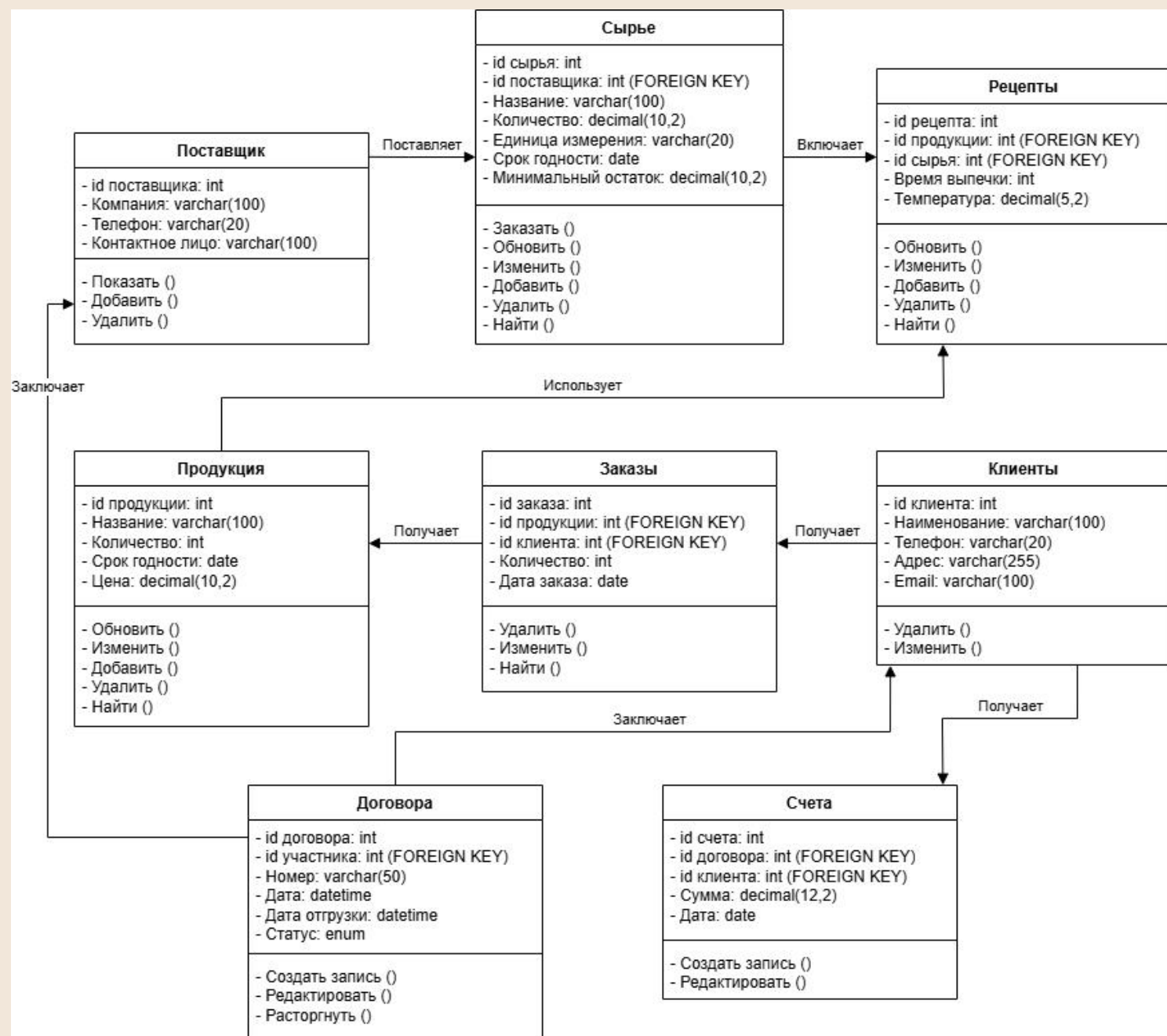
JSONB

снимки
old_data/new_data в аудите

Пример ограничения

```
UNIQUE invoice(order_id) WHERE status IN (issued, overdue, paid)
```


Физическая модель PostgreSQL



Авторизация пользователей

Что реализовано

- пользователь проходит форму входа
- сервер загружает запись из users
- при ошибке вход не выполняется
- успешный вход фиксируется в сессии

Показывает, что доступ к разделам невозможен без авторизации.

ИС хлебозавода

Войдите, чтобы открыть локальный интерфейс курсовой работы.

Неверный логин или пароль.

Логин

admin

Пароль

Войти

Локальный демонстрационный интерфейс для курсовой работы по PostgreSQL.

Хранение паролей

Что реализовано

- Пароль преобразуется в bcrypt-хэш
- В users хранится только password_hash
- Одинаковые пароли получают разные хэши
- Проверка выполняется через verify

username	password_hash
admin	\$2a\$12\$jkKp8E0fanhlN/eJFXojXum4aixFdyzzr4yDF3srea0daReXAVGEO
client	\$2a\$12\$z1IwsEkJBr5jNgiloBCqMuoaKnt5IasBXe8HuBXVc0xrzEojWcXE.
quality	\$2a\$12\$RhUwYfUPeOnWUEGDwLjfw0bgqxXAQXHcEbZwM07TYH5HL.qX4taPO
technologist	\$2a\$12\$bFJBjKSrwt05057/5W0Xh0oe5VI/ZIMKo10Y5VTvmtD1D2yx2Zbwq
warehouse	\$2a\$12\$b8ckK1gpo6CH2.GdJljRx.npceD7hAu1jrhU79S.KCr3CTDhRx2du
(5 rows)	

Защита от SQL-инъекций

Что реализовано

- SQL-текст и значения разделены
- используются плейсхолдеры %s
- выполнение идёт через `cur.execute(query, params)`
- строка `OR 1=1` не меняет логику запроса

Инъекция воспринимается как обычное значение поля формы.

ИС хлебозавода

Войдите, чтобы открыть локальный интерфейс курсовой работы.

Неверный логин или пароль.

Логин

admin' OR '1'='1

Пароль

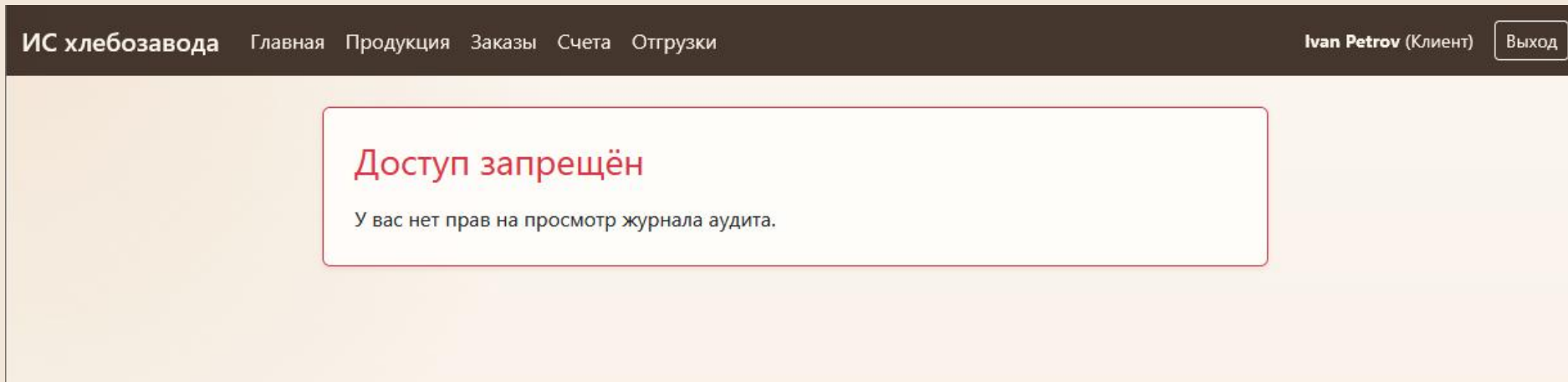
Войти

Локальный демонстрационный интерфейс для курсовой работы по PostgreSQL.

Ролевая модель доступа

Что реализовано

- используются роли admin, client, technologist, warehouse, quality
- разделы скрываются по SECTION_RULES
- критичные действия проверяются по ACTION_RULES
- при прямом URL возвращается 403



Ролевая модель доступа

ИС хлебозавода

Главная

Продукция

Заказы

Счета

Отгрузки

Ivan Petrov (Клиент)

Выход

Личный кабинет

Личный кабинет клиента со статусами заказов, счетами, отгрузками и доступной продукцией.

ТЕКУЩИЙ ПОЛЬЗОВАТЕЛЬ
client

МОИ ЗАКАЗЫ

4

МОИ СЧЕТА

3

МОИ ОТГРУЗКИ

2

ДОСТУПНАЯ ПРОДУКЦИЯ

4

ИС хлебозавода

Главная

Клиенты

Поставщики

Сырьё

Поставки

Остатки сырья

Продукция

Техкарты

Заказы

Производство

Готовая продукция

Качество

Счета

Счета поставщиков

Отгрузки

Отчёты

Аудит

Пользователи и роли

Alexey Morozov (Администратор)

Выход

Главная

Сводка по работе базы данных хлебозавода.

ТЕКУЩИЙ ПОЛЬЗОВАТЕЛЬ
admin

КЛИЕНТЫ

3

ЗАКАЗЫ

6

ПРОДУКЦИЯ

4

СЫРЬЁ

7

Ограничения целостности

Что реализовано

- CHECK запрещает отрицательные суммы и неверные даты
- FOREIGN KEY запрещает ссылки на несуществующие записи
- UNIQUE предотвращает дубли документов
- ограничения работают независимо от интерфейса

```
bakery_security_db=# BEGIN;
```

```
UPDATE invoices  
SET amount = -100  
WHERE invoice_id = 1;  
BEGIN  
ERROR:  new row for relation "inv  
DETAIL:  Failing row contains (1,  
        Paid immediately after shipment.  
bakery_security_db=!# ROLLBACK;  
ROLLBACK
```

```
bakery_security_db=# bakery_security_db=# BEGIN;
```

```
UPDATE invoices  
SET order_id = 999999999  
WHERE invoice_id = 1;  
BEGIN  
ERROR:  insert or update on table  
DETAIL:  Key (order_id)=(999999999  
bakery_security_db=!# ROLLBACK;  
ROLLBACK  
bakery_security_db=# |
```

Аудит действий пользователей

Что реализовано

- записываются INSERT, UPDATE, DELETE, LOGIN, LOGOUT
- хранятся пользователь, время и таблица
- old_data и new_data сохраняются в JSONB
- аудит доступен только администратору

Главная

Клиенты

Поставщики

Сырьё

Поставки

Остатки сырья

Продукция

Техкарты

Заказы

ИС хлебозавода

Производство

Готовая продукция

Качество

Счета

Счета поставщиков

Отгрузки

Отчёты

Аудит

Alexey Morozov
(Администратор)

Выход

Все пользователи

Пользователи и роли

Все таблицы

Все действия

Детали

Применить фильтры

ID	Когда	Пользователь	Действие	Таблица	Запись	Успех
172	2026-05-12 21:45:08.925094+00:00	admin	Вход	users	user_id=1	Да
171	2026-05-12 21:45:08.925094+00:00	admin	Изменение	users	user_id=1	Да
170	2026-05-12 21:45:00.669180+00:00	client	Выход	users	user_id=5	Да

Резервное копирование

Что реализовано

- используется команда `pg_dump`
- сохраняются структура БД и данные
- формируется файл `.backup` в формате `custom`
- резервная копия нужна для восстановления после сбоя

```
PS C:\Users\sakurelle\documents\Slop Bakery> docker compose --env-file configuration.yml exec db sh -c "pg_dump -U bakery_admin_user -d bakery_security_db -F c -fs -lh /tmp/bakery_security_db_full.backup"
-rw-r--r-- 1 root root 130K May 12 21:48 /tmp/bakery_security_db_full.backup
PS C:\Users\sakurelle\documents\Slop Bakery> |
```

Заказ и оплата

1. Каталог

клиент выбирает
активную
продукцию

2. Заказ

создаётся только
для текущего
клиента

3. Счёт

сумма считается
по позициям
заказа

4. Оплата

paid_at
заполняется при
оплате

Защита от подмены

customer_id, status_code и
unit_price игнорируются или
назначаются сервером.

Целостность счёта

второй активный счёт по
заказу блокируется индексом
и проверкой приложения.

Доступ клиента

оплата разрешена только для
собственного issued или
overdue invoice.

Поставки и производство

Поставка сырья

Сырьё добавляется только если оно закреплено за поставщиком. Цена и срок поставки берутся из `supplier_materials`.

Склад сырья

`planned`-поставка не увеличивает остатки; партия появляется после приёмки и расчёта срока годности.

Производство

Запуск возможен только по `active tech card` и при достаточном объёме проверенного сырья.

Зачем это нужно

Исключаются поставки неподходящего сырья, ручная подмена цены и производство без реального сырьевого обеспечения.

Результат операции

После `completed`-производства списывается сырьё и создаётся партия готовой продукции, доступная для контроля качества.

Качество и отгрузка

1. Проверка

passed quality
check обязателен
для сырья и
готовой продукции.

2. Оплата

заказ нельзя
отгрузить без paid
invoice.

3. Склад

учитываются
только
непросроченные
партии с
положительным
остатком.

4. Отгрузка

shipment item
списывает
finished_goods_stoc
k транзакционно.

Серверные проверки

нельзя отгрузить больше заказанного,
выбрать партию другого продукта или
провести shipment без покрытия позиций.

Печатная форма

отчёт по конкретной отгрузке доступен
складу, администратору и клиенту только
для своих данных.